

Care Access Navigator

Risk Management Rubric - Criterion 4: Risk Mitigation Planning

Purpose

This criterion is taking the evaluated risks from the earlier risk assessment and turning them into practical treatment actions. The focus is on selecting controls, explaining why they are appropriate, estimating cost and benefit, assigning implementation timelines and resources, calculating residual risk, and defining how control effectiveness will be monitored.

1. Select Controls Using Industry Frameworks

- What:** Selecting safeguards for the main Identity and Access Management (IAM), access-governance, and monitoring risks in Care Access Navigator.
- How:** Using the National Institute of Standards and Technology (NIST) Cybersecurity Framework as the primary organizing framework and using International Organization for Standardization / International Electrotechnical Commission (ISO/IEC) 27001 control concepts as supporting reference points. Controls are being matched to the specific vulnerability or risk they are reducing.
- Why:** A mitigation plan is stronger when each control is traceable to a recognized security framework and to a specific project risk rather than being selected only because it sounds useful.

Risk	Selected Control	Framework Alignment	Reason for Selection
R01 Excessive Role-Based Access Control (RBAC) privileges	Least-privilege role design; quarterly access review; manager certification	NIST CSF: Protect - Identity Management, Authentication and Access Control; ISO/IEC 27001 access-control concepts	Reducing excessive access by aligning permissions to job responsibilities and periodically reviewing assignments.
R02 Terminated account remains active	Joiner-Mover-Leaver (JML) deprovisioning workflow; account-disable verification	NIST CSF: Protect - Identity Management; ISO/IEC 27001 identity lifecycle concepts	Reducing stale-account exposure by removing access promptly when employment or authorization ends.
R03 Credential compromise	Multi-Factor Authentication (MFA); password policy; failed-login monitoring	NIST CSF: Protect/Detect; ISO/IEC 27001 authentication and monitoring concepts	Adding a second authentication factor and monitoring suspicious login behavior reduces reliance on passwords alone.
R04 Privileged account misuse	Restricted privileged roles; separate admin accounts; privileged-access review; alerting	NIST CSF: Protect/Detect; ISO/IEC 27001 privileged-access concepts	Privileged accounts can change identities, roles, or security settings, so stronger governance and monitoring are justified.
R05 Expired vendor access	Owner assignment; expiration date; periodic review; automated/verified disablement	NIST CSF: Protect - Identity Management; ISO/IEC 27001 supplier/access-control concepts	Third-party access is being limited to the approved business period and reviewed before it becomes stale.

2. Document the Four Risk Treatment Strategies

- What:** Showing how Care Access Navigator is using the four standard risk treatment choices: mitigate, avoid, transfer, and accept.
- How:** Assigning a treatment decision to each risk or project condition based on the practical simulated environment, the expected benefit of further controls, and the amount of residual risk that remains.
- Why:** The rubric requires all four treatment strategies to be demonstrated. Using all four also shows that not every risk should automatically be handled in the same way.

Strategy	Care Access Navigator Example	How it is being applied
Mitigate	Credential compromise, excessive RBAC access, stale accounts	Implementing MFA, least privilege, access reviews, logging, alerting, and lifecycle controls to reduce likelihood or impact.
Avoid	Using real patient data or unnecessary production integrations	Keeping the project synthetic and non-production, which removes privacy and production-system risk that is not needed for the learning objective.

Strategy	Care Access Navigator Example	How it is being applied
Transfer	Selected infrastructure/service availability responsibility	Using hosted/lab platform capabilities where appropriate so some infrastructure responsibility is carried by the underlying service provider; this does not transfer accountability for access governance.
Accept	Low-impact limitations of the simulated lab	Documenting and accepting limitations such as lightweight mock applications when the remaining risk is within the project tolerance and further treatment would not materially improve the learning outcome.

3. Perform Cost-Benefit Analysis

What:	Comparing the estimated implementation effort of a control with the amount of risk reduction and operational value it is expected to provide.
How:	Using starter educational estimates for effort and cost, comparing them with the financial exposure and risk scores already developed, and documenting whether the control provides high, medium, or low value.
Why:	A control may reduce risk but still be impractical. Cost-benefit analysis is helping justify why a selected control is worth implementing in the project.

Control / Action	Starter Cost / Effort	Expected Benefit	Decision
Enable and test MFA for privileged/admin users	Low-Medium: configuration + test effort	High reduction in credential-compromise likelihood for the most powerful accounts	Implement
Quarterly access review with remediation log	Low: analyst/manager review time	High visibility into excessive, stale, mismatched, and vendor access	Implement
JML disablement verification	Low-Medium: workflow + test effort	High reduction in stale-account risk and better evidence of lifecycle control	Implement
Full enterprise Privileged Access Management platform	High relative to capstone scope	High security value, but excessive cost/complexity for a lightweight 12-week simulation	Defer / simulate concept
Real production Electronic Health Record integration	Very High and introduces privacy/production risk	Not required to demonstrate the learning objectives	Avoid

4. Build the Implementation Timeline and Resource Plan

What:	Turning the selected controls into scheduled implementation activities with clear owners and required resources.
How:	Using the existing project roles and tools - Keycloak, Microsoft Sentinel or equivalent log analysis, Monday.com, Microsoft Word/Excel, and Tableau - and assigning realistic implementation windows to each mitigation activity.
Why:	A treatment decision is not complete until it has an owner, target timing, and the resources needed to implement and validate it.

Mitigation Activity	Owner	Timing	Resources / Evidence
Validate RBAC and least-privilege mappings	IAM Analyst	1 week	RBAC matrix, Keycloak roles, representative access tests
Test Joiner-Mover-Leaver deprovisioning	IAM Analyst + HR/Workforce role	1 week	JML workflow, account status screenshots, verification record
Enable/test MFA and privileged-role controls	IAM Analyst + Security Analyst	1 week	Keycloak authentication settings, privileged-role review, test cases
Create failed-login / privilege-escalation / vendor-expiry detections	Security Analyst	1-2 weeks	Synthetic logs, Sentinel/equivalent detections, alert evidence
Perform access review and remediation	GRC Analyst + Department Manager	1 week	Access review list, findings, approvals, remediation log
Update risk register and residual risk	GRC Analyst	Ongoing after each control	Risk register, evidence index, control test results

5. Calculate Residual Risk After Control Implementation

What:	Re-scoring each risk after the planned controls are considered so the remaining risk is visible.
How:	Using the same 1-5 likelihood and impact scales from the earlier risk assessment, lowering scores only where a control is expected to reduce likelihood or impact and keeping the original inherent score for comparison.
Why:	Residual risk shows whether the mitigation is sufficient or whether more treatment, monitoring, or formal acceptance is needed.

Risk	Inherent L x I	Planned Control Effect	Residual L x I	Residual Rating
R01 Excessive RBAC privileges	4 x 5 = 20	Least privilege + access review reduces likelihood	2 x 5 = 10	High
R02 Terminated account remains active	3 x 5 = 15	JML disablement verification reduces likelihood	1 x 5 = 5	Moderate
R03 Credential compromise	4 x 5 = 20	MFA + login monitoring reduces likelihood	2 x 5 = 10	High
R04 Privileged account misuse	3 x 5 = 15	Restricted admin roles + monitoring reduces likelihood	2 x 5 = 10	High
R05 Expired vendor access	3 x 4 = 12	Expiration + review reduces likelihood	1 x 4 = 4	Low

Residual scores are starter estimates. They should be confirmed only after the relevant control is implemented and tested.

6. Define Effectiveness Measures and Monitoring Procedures

What:	Defining how the project is checking whether each mitigation control is actually working over time.
How:	Using control tests, exception tracking, periodic access review, alert metrics, and risk-register updates. Evidence is being linked to the control and risk so that ineffective or failed controls can trigger remediation.
Why:	A control is not considered effective just because it exists. Monitoring and measurement are showing whether the control is producing the expected risk reduction.

Control	Effectiveness Measure	Monitoring / Review
MFA for privileged accounts	100% of privileged/admin accounts enrolled; successful MFA test evidence	Review after configuration changes and during privileged-access review
JML deprovisioning	Leaver account disabled within target time; no active access after test	Test representative leaver scenarios; review exceptions
RBAC / least privilege	No unauthorized permissions in sampled role tests; access-review exceptions remediated	Quarterly access review or project simulation equivalent
Failed-login / security alerts	Alert generated for controlled test event; triage completed and documented	Review alert results and missed detections after each test
Vendor expiration	Expired vendor account disabled or reviewed before expiry	Periodic vendor-account review

7. Criterion 4 Result

For Criterion 4, Care Access Navigator is creating a complete mitigation plan that links project risks to recognized control frameworks, demonstrates mitigate/avoid/transfer/accept decisions, documents cost-benefit reasoning, assigns owners and implementation timing, estimates residual risk, and defines how each control will be tested and monitored.

Important note: Cost, timeline, and residual-risk values are starter planning values for the simulated project. Final values should be updated using actual implementation evidence and test results.